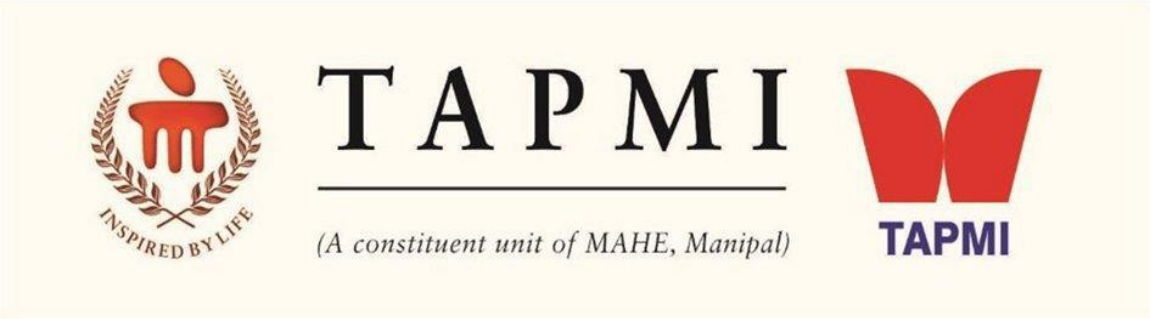
CYBERSECURITY PROJECT REPORT

BUSINESS PROBLEM



NAME: POOJITHA K

ID: 251620140002

Background

SecureBank is a retail bank moving its services online. Customers need a portal where they can log in, check their balance and accounts, transfer money, view their statement, manage cards and payees, and raise support tickets. Because the portal handles real money and personal data, it is a valuable target. A single weakness can let an attacker steal money, read other people's accounts, or trick a customer into giving away their card details. The bank's reputation and its customers' trust depend on getting the security right from the start, not patching it later.

The problem

The bank must build this portal so it is safe to use. In simple terms, it must keep three promises, which security professionals call the CIA triad: keep customer data private (Confidentiality), make sure nobody can tamper with it (Integrity), and keep the service available and hard to abuse (Availability). It must also manage identity properly — prove who a user is, let each person reach only their own data,

store passwords safely, and resist fake or forged requests. If any of these fail, money and data are at risk.

Objectives

- Let customers sign in with more than just a password.
- Make sure a customer can see and move money only from their own account.
- Make sure every action comes from the real user, not a forged or fake request.
- Never send a customer to an untrusted website after they log in.
- Store passwords and card data so that a leak does not expose anything usable.

Who is affected (stakeholders)

- Customers - want their money and personal data safe.
- The bank's security, IT team, Leadership team - build, run ,defend the portal
- Regulators - in India the RBI sets cyber rules; globally PCI DSS and ISO 27001 apply.

How we will know it is solved (success criteria)

1. An independent security scan finds no high or medium problems in the final code.
2. Common attacks - SQL injection, access-control abuse, forged requests, fake-link redirects and password guessing - are shown to be blocked, not just claimed.
3. Passwords and card details are never stored or shown in a form an attacker could reuse.

Scope

In scope: The customer-facing portal and the security work around it. On the app side: login and the one-time-password (OTP) step, the dashboard with balance and account summary, accounts and statements, money transfers to payees, transaction history, payees, the cards page, the profile page, and support tickets. On the security side: the full test-and-fix cycle — building the app, finding the flaws, a manual review, and producing a hardened fixed version with proof it works.

Out of scope: The real core-banking ledger, external payment networks, live hosting, real SMS and email gateways (the OTP is simulated), hardware key management, and formal PCI DSS certification.

The portal is a small, self-contained demo, so every problem and fix can be followed end to end.